



LEVEL 201 - DOMAIN OVERVIEW & ASSESSMENT

Full Maturity Assessment Enablement Guide

A comprehensive guide for conducting Digital Sovereignty, AI Sovereignty, and Security maturity assessments

Version 1.3 - 29th April 2026

Table of Contents

Introduction

Pre-Assessment Preparation

Facilitation Methodology

Domain Deep-Dives

Post-Assessment Activities

Facilitator Tips & Best Practices

Appendix

Downloadable Templates(<templates/index.html>)

Introduction

Enablement Guide Levels

This is the **201 - Domain Overview & Assessment** guide. Other levels available:

101 - Introduction to Digital Sovereignty (facilitator-guide-101.php) - Executive overview (1-2 hours)

201 - Domain Overview & Assessment - Full assessment (2-4 hours)
[You are here]

301 - Deep Dive Implementation - Coming soon

Purpose of This Guide

This **Level 201** Enablement Guide provides comprehensive instructions for conducting Full Maturity Assessments with customers and partners. It is designed for technical managers, solution architects, and workshop facilitators who need to deliver consistent, high-quality assessments that provide valuable insights into an organization's Digital Sovereignty, AI Sovereignty, and Security maturity.

This guide assumes familiarity with basic Digital Sovereignty concepts. If you or your audience are new to Digital Sovereignty, consider starting with the [101 - Introduction guide \(facilitator-guide-101.php\)](#).

What is a Full Maturity Assessment?

The Full Maturity Assessment is a structured evaluation tool that measures an organization's capabilities across multiple domains using a proven 5-level maturity model based on the CMMI (Capability Maturity Model Integration) framework:

Level	Name	Range	Description
Level 1	Initial	0-20%	Unpredictable, reactive processes; ad-hoc approach
Level 2	Managed	21-40%	Planned and executed processes; basic controls in place
Level 3	Defined	41-60%	Standardized and documented processes across organization
Level 4	Quantitatively Managed	61-80%	Measured and controlled processes with metrics
Level 5	Optimizing	81-100%	Continuous improvement and innovation

Assessment Profiles

We offer three primary assessment profiles, each focused on different organizational priorities:

Digital Sovereignty

5 Main Domains: Data Sovereignty, Technical Sovereignty (includes Open Source sub-pillar), Operational Sovereignty (includes Managed Services sub-pillar), Assurance Sovereignty, Executive Oversight (cross-cutting)

Focus: Organizational control and independence from external dependencies, particularly important for government, healthcare, finance, and organizations with strict data residency requirements.

AI Sovereignty

7 Domains: AI Data Sovereignty, AI Model Sovereignty, AI Infrastructure Sovereignty, AI Supply Chain Sovereignty, AI Governance & Compliance, AI Operations Sovereignty, AI Innovation Sovereignty

Focus: Control over AI/ML systems, models, training data, and infrastructure. Essential for organizations deploying AI at scale, subject to AI regulations (EU AI Act), or requiring explainable and sovereign AI solutions.

Security

7 Domains: Secure Infrastructure, Secure Data, Secure Identity, Secure Application, Secure Network, Secure Recovery, Secure Operations

Focus: Comprehensive security posture across all layers of the technology stack, ideal for compliance-driven organizations and those with high security requirements.

Tip

Most organizations benefit from starting with **Digital Sovereignty** to address strategic independence concerns. Organizations deploying AI/ML workloads should also consider the **AI Sovereignty** profile to ensure control over AI systems and compliance with emerging AI regulations. Security assessments can follow to provide deeper technical security insights.

Pre-Assessment Preparation

Scheduling the Assessment

Proper preparation is critical to a successful assessment. Consider the following when scheduling:

Time Requirements

Full Assessment: 2-4 hours depending on organization size and complexity

Quick Assessment: 1-2 hours (covering only Foundation tier questions)

Follow-up Session: 1 hour (for results review and roadmap planning)

Participant Selection

The assessment requires input from multiple stakeholders to ensure accurate ratings. Recommended participants:

Role	Why They're Needed	Essential?
CIO / CTO	Strategic oversight, budget authority, executive-level questions	Yes
CISO / Security Lead	Security controls, risk management, compliance frameworks	Yes
Cloud/Infrastructure Lead	Technical sovereignty, infrastructure control, vendor relationships	Yes

Role	Why They're Needed	Essential?
Compliance/Legal Officer	Data residency, jurisdictional control, regulatory requirements	Recommended
Operations Manager	Operational processes, disaster recovery, managed services	Recommended
Procurement Lead	Vendor management, supply chain, contract terms	Optional

Industry (LOB) Selection

Selecting the appropriate Line of Business (LOB) is crucial as it applies industry-specific weightings to domains. Guide your customer through this decision:

Finance

Best for: Banks, insurance companies, financial services, payment processors

Emphasized domains: Data Sovereignty (2.0×), Assurance Sovereignty (2.0×), Operational Sovereignty (1.5×)

Rationale: Financial institutions face stringent regulatory requirements (PCI DSS, SOX, DORA) demanding strong data protection, audit controls, and business continuity.

Healthcare

Best for: Hospitals, health systems, medical research, healthcare technology

Emphasized domains: Data Sovereignty (2.0×), Operational Sovereignty (2.0×)

Rationale: Healthcare organizations must protect sensitive patient data (HIPAA, GDPR) while maintaining 24/7 operational resilience for patient safety.

Government

Best for: Federal/state/local government, public sector, defense contractors

Emphasized domains: Data Sovereignty (2.0×), Assurance Sovereignty (2.0×), Executive Oversight (2.0×)

Rationale: Government entities handle sensitive citizen data and critical infrastructure with strict sovereignty requirements, transparency needs, and national security concerns.

Manufacturing

Best for: Industrial manufacturing, automotive, aerospace, discrete manufacturing

Emphasized domains: Operational Sovereignty (2.0× - includes Managed Services sub-pillar)

Rationale: Manufacturers prioritize production uptime, OT/IT integration, and IP protection for proprietary designs and processes.

Telecommunications

Best for: Telecom providers, ISPs, mobile carriers, network infrastructure

Emphasized domains: Data Sovereignty (2.0×), Operational Sovereignty (2.0×), Assurance Sovereignty (2.0×)

Rationale: Telecom operators manage critical communications infrastructure with subscriber data protection requirements and strict regulatory compliance (NIS2).

Balanced / Other

Best for: Organizations without specific industry focus or those spanning multiple sectors

Emphasized domains: All domains equally weighted (1.0×)

Rationale: Provides an unbiased assessment across all domains without industry-specific emphasis.

Pre-Assessment Checklist

Send this checklist to participants at least 1 week before the assessment:

Pre-Assessment Information Needed

Current cloud infrastructure provider(s) and services used

List of critical business applications and their hosting locations

Existing compliance frameworks and certifications (ISO 27001, SOC 2, etc.)

Data classification policies and data residency requirements

Key vendor relationships and managed service providers

Recent security audits or risk assessments

Disaster recovery and business continuity documentation

Open source usage policies (if applicable)

Technical Setup

Before the session, ensure:

Access to the assessment tool at the appropriate URL

Screen sharing capability if conducting remotely

Backup recording/note-taking method in case of technical issues

Sample results ready to show (if first-time participants)

Facilitation Methodology

Workshop Structure

A well-structured session keeps participants engaged and ensures comprehensive coverage of all domains.

- 0:00-0:15 - Introduction & Context Setting (15 min)
Explain assessment purpose, maturity model, review agenda, confirm participants and roles
- 0:15-0:25 - Profile & Industry Selection (10 min)
Discuss and select appropriate assessment profile and industry weighting
- 0:25-2:25 - Domain Assessment (120 min)
Work through each domain systematically (~24 min per domain for 5 main domains)
- 2:25-2:45 - Results Review (20 min)
Review spider chart, discuss scores, identify obvious gaps
- 2:45-3:00 - Next Steps & Wrap-up (15 min)
Discuss next steps, schedule follow-up, export results

Time Management

Sessions often run long as participants want to discuss their challenges.
Build in buffer time or be prepared to schedule a continuation session.
Consider breaking complex assessments into multiple shorter sessions.

Opening Script

Use this script to open your assessment session professionally:

Sample Opening

"Thank you all for joining today's Full Maturity Assessment. Over the next 2-3 hours, we'll be evaluating your organization's capabilities across [Digital Sovereignty / Security] domains using a proven 5-level maturity framework."

"This assessment is designed to be honest and constructive—not punitive. Most organizations score between levels 2-3 initially, and that's perfectly normal. The goal is to establish a baseline and identify priority areas for improvement."

"I'll be asking questions about your current capabilities and asking for evidence of implementation. Please be candid—overestimating maturity only hurts your own planning. If you're unsure about an answer, we can flag it for follow-up."

"Let's start by selecting your industry profile, which will adjust the weighting of domains based on your sector's specific needs..."

Question-by-Question Guidance

How to Score Each Capability

Each capability is rated using a slider with four implementation status levels. Guide participants through this process:

Capability Rating Scale

Each capability uses a 0-3 slider to indicate implementation status:

- 0 - No Capability:** Not implemented, no plans, or not applicable
- 1 - In Planning:** Being planned or early-stage consideration
- 2 - Work in Progress:** Partially implemented or in active deployment
- 3 - Fully Complete:** Fully implemented, documented, and operational

Note: These capability ratings contribute to the overall 5-level maturity score for each domain.

Read the capability aloud - Ensure everyone understands what's being assessed

Discuss current state - Ask about current implementation status

Ask for evidence - "Can you show me documentation/tools/policies that demonstrate this?"

Probe deeper - "Walk me through how this actually works in practice"

Watch for inflation - Organizations often overestimate; look for concrete proof

Use the slider - Select the appropriate implementation status (0-3) based on evidence

Seek consensus - If participants disagree, facilitate discussion to reach agreement

Document notes - Use the notes field to capture important context and evidence

Evidence-Based Assessment

Always ask for evidence to support capability ratings. Here are examples of acceptable evidence for each implementation status:

Status	Slider Value	Acceptable Evidence Examples
No Capability	0	Verbal confirmation of gap, acknowledgment that capability doesn't exist, no current plans
In Planning	1	Project proposals, budget requests, initial requirements gathering, vendor evaluations, roadmap items
Work in Progress	2	Draft policies, active projects, pilot implementations, partial rollouts, some teams using it, configuration in progress

Status	Slider Value	Acceptable Evidence Examples
Fully Complete	3	Approved policies, documented procedures, organization-wide implementation, training completed, metrics being collected, regular reviews occurring

Common Pitfall

Don't confuse capability status with overall maturity: A single capability rated "Fully Complete" (3) doesn't mean the organization is at "Optimizing" maturity level (Level 5). The overall maturity rating is calculated across all capabilities in a domain based on the percentage of possible points achieved.

Handling Difficult Conversations

Scenario: Stakeholders Disagree on Rating

Example: The CIO believes they have Level 4 disaster recovery, but the Operations Manager says they've never successfully tested it.

Response: "I'm hearing different perspectives here. Let's focus on what we can verify. [Operations Manager], can you describe your most recent DR test? [CIO], what metrics are you using to assess DR maturity? Based on industry best practices, regular testing is required for Level 4. Without test evidence, we should consider Level 2 or 3."

Approach: Stay neutral, ask for evidence, refer to maturity definitions, help them reach consensus based on facts.

Scenario: Customer is Defensive About Low Scores

Example: After several Level 1-2 scores, the CISO becomes defensive: "We have excellent security! This assessment is unfair!"

Response: "I appreciate your commitment to security. These scores reflect maturity along a journey—they're not a judgment of your team's effort or capability. Many excellent organizations score at Level 2-3 initially. The assessment helps us identify where focused investment will have the most impact. Would it help to review the scoring criteria together?"

Approach: Validate their feelings, emphasize growth mindset, reframe scores as opportunities, avoid blame.

Scenario: "We Don't Know" Responses

Example: Multiple participants don't know the answer to questions about vendor contracts or key management.

Response: "That's valuable information in itself—if key stakeholders don't know, that typically indicates Level 1 or 2 maturity. Let's mark this for follow-up investigation and make a provisional rating of Level 1. You can update it later once you've verified."

Approach: Frame "don't know" as data, assign conservative rating, offer to revisit, ensure follow-up action item is captured.

Maintaining Momentum

Keep the assessment moving while ensuring thoroughness:

Set time limits - Allocate ~2-3 minutes per question; use a visible timer

Park discussions - "That's an important topic; let's capture it for the roadmap discussion and continue"

Batch related questions - "These next 3 questions are all about encryption; let's discuss them together"

Take strategic breaks - Break between domains (5 min every 45 min)

Show progress - "We're through 3 of 5 domains—great progress!"

Domain Deep-Dives

This section provides detailed guidance for each domain. Each domain contains 8 capabilities organized by importance tiers (this helps prioritize questions, but does not determine the final maturity rating):

Foundation Tier (Capabilities 1-3): Basic capabilities and policies - essential starting points

Strategic Tier (Capabilities 4-6): Advanced implementation and control - building on foundations

Advanced Tier (Capabilities 7-8): Optimization and continuous improvement - achieving excellence

Understanding the 5-Level Maturity Model

Important: The capability tiers above (Foundation/Strategic/Advanced) categorize *questions* by importance. The **maturity levels** below describe the *assessment outcome* based on total scores achieved.

Maturity Levels (0-36 points per domain):

Initial (0-7.2 points): Ad-hoc, unpredictable, reactive processes

Managed (7.2-14.4 points): Processes planned and tracked, but still reactive

Defined (14.4-21.6 points): Processes documented, standardized, and proactive

Quantitatively Managed (21.6-28.8 points): Processes measured and controlled

Optimizing (28.8-36 points): Focus on continuous improvement and innovation

How scores are calculated: For each capability, your implementation level (slider 0-3: No Capability, In Planning, Work in Progress, Fully Complete) is converted to a percentage (0%, 33%, 67%, or 100%), then multiplied by the

capability's point value (1-8). The domain's total score (max 36) determines its maturity level.

Example: A 5-point capability rated "Work in Progress" contributes $67\% \times 5 = 3.33$ points to the domain total.

Domain 1: Data Sovereignty

Domain Overview

This domain assesses an organization's ultimate control over its data, independent of external jurisdictions or political influences. It goes beyond basic data residency by focusing on legal control, access, and encryption management. Maturity here confirms that data location is actively governed by the organization's legal and business requirements, rather than dictated solely by a cloud provider or foreign law.

Key Concepts to Explain

Data Residency vs. Data Sovereignty: Residency = where data physically resides; Sovereignty = legal control and ability to resist foreign access demands

Jurisdictional Control: Ensuring data and access are governed by domestic law, not foreign legal frameworks like the CLOUD Act

Encryption Key Management: The entity controlling encryption keys ultimately controls access to data, regardless of where it's stored

Data-in-Use Protection: Protecting data during processing, not just at rest and in transit

Common Customer Misconceptions

Watch Out For

"We use a local cloud region, so we have data sovereignty" - Physical location alone doesn't guarantee sovereignty if the provider is subject to

foreign law

"Encryption protects our sovereignty" - Not if the cloud provider controls the keys or can be compelled to decrypt

"GDPR compliance means we have data sovereignty" - Compliance is necessary but not sufficient for true sovereignty

"We don't have sensitive data" - Most organizations underestimate the sensitivity and value of their data assets

Domain 1 Question Guide

Q1: Data Residency & Location (1 point - Foundation)

What this measures: Whether the organization explicitly controls where data is stored based on legal requirements

Key questions to ask:

"Do you have a written data residency policy?"

"Can you show me which cloud regions your data is stored in?"

"How do you prevent data from being accidentally stored outside approved regions?"

"What happens if a cloud provider wants to move your data for operational reasons?"

Evidence to request: Data residency policy document, cloud provider contracts specifying regions, configuration screenshots showing geo-restrictions

Red flags: "We think it's in [region]", "The cloud provider handles that", "We haven't checked recently"

Q2: Data Protection & Privacy (2 points - Foundation)

What this measures: Compliance with data protection regulations and implementation of privacy controls

Key questions to ask:

"Which data protection regulations apply to you? (GDPR, CCPA, PIPL, etc.)"

"How do you handle data subject rights requests (access, deletion, portability)?"

"Do you have a Data Protection Officer or equivalent role?"

"How are cross-border data transfers authorized and tracked?"

Evidence to request: Privacy policies, consent management systems, GDPR compliance documentation, Privacy Impact Assessments

Red flags: Confusion about applicable regulations, no defined process for data subject requests, relying solely on vendor certifications

Q3: Data Classification and Inventory (3 points - Foundation)

What this measures: Whether the organization knows what data it has, where it is, and how sensitive it is

Key questions to ask:

"Do you have a complete inventory of your data assets?"

"What classification levels do you use? (Public, Internal, Confidential, Restricted)"

"How do you discover and classify new data automatically?"

"Who owns each data asset and is accountable for its protection?"

Evidence to request: Data inventory/catalog, classification framework document, data discovery tool demonstrations, data ownership registers

Red flags: "We're working on that", manual spreadsheet-based tracking, no data ownership assigned

Q4: Legal & Jurisdictional Control (4 points - Strategic)

What this measures: Ability to resist extra-territorial legal demands and maintain domestic legal control

Key questions to ask:

"What jurisdiction's law governs your cloud contracts?"

"How would you respond to a foreign government data access request?"

"Do you have contractual provisions requiring vendors to notify you of legal demands?"

"Have you assessed conflicts between foreign laws (CLOUD Act) and domestic requirements?"

Evidence to request: Vendor contracts showing governing law clauses, legal risk register, documented escalation procedures

Red flags: Contracts governed by foreign law, no notification provisions, unaware of jurisdictional conflicts

Q5: Cryptographic Key Management Control (6 points - Strategic)

What this measures: Whether the organization exclusively controls encryption keys, independent of cloud providers

Key questions to ask:

"Who generates and stores your encryption keys?"

"Can your cloud provider access your encryption keys?"

"Do you use HSMs (Hardware Security Modules)? Where are they located?"

"How frequently do you rotate encryption keys?"

"What would happen if your provider received a legal demand to decrypt your data?"

Evidence to request: Key management architecture diagrams, HSM procurement/contracts, key rotation policies, external key management (EKM) solution documentation

Red flags: Provider-managed keys, lack of HSMs, no key rotation schedule, unclear about who can access keys

Note: This is a 6-point question because key control is fundamental to data sovereignty. Organizations often struggle here.

Q6: Workload Data Protection & Privacy (5 points - Strategic)

What this measures: Protection of data during processing (data-in-use), not just storage and transit

Key questions to ask:

"How do you protect data while it's being processed in memory?"

"Are you using confidential computing or Trusted Execution Environments (TEEs)?"

"Can cloud administrators access data in memory during processing?"

"How do you ensure sensitive data isn't logged in plaintext?"

Evidence to request: Confidential computing implementations (Intel SGX, AMD SEV, AWS Nitro Enclaves), memory encryption configurations, log sanitization policies

Red flags: Unaware of data-in-use protection, relying only on at-rest and in-transit encryption, plaintext logging of sensitive data

Note: This is often Level 1-2 for most organizations; confidential computing is still emerging.

Q7: Data Flow and Transfer Auditing (7 points - Advanced)

What this measures: Real-time monitoring and immutable logging of all data movements

Key questions to ask:

"Can you show me where your data flows across systems?"

"Do you have Data Loss Prevention (DLP) tools deployed?"

"How do you monitor and prevent unauthorized data transfers?"

"Are your audit logs immutable and stored sovereignly?"

"How quickly can you detect an unauthorized cross-border data transfer?"

Evidence to request: Data flow maps, DLP dashboards, audit log retention policies, SIEM integration, transfer blocking evidence

Red flags: No data flow visibility, reactive rather than preventive controls, logs stored with cloud provider

Q8: Data Access by Third Parties Policies (8 points - Advanced)

What this measures: Strict, audited, and revocable control over vendor and partner access to data

Key questions to ask:

"Which third parties have access to your data? Why?"

"Do you use Just-in-Time (JIT) access for vendor support?"

"How do you monitor and record third-party access sessions?"

"Can you immediately revoke vendor access in an emergency?"

"Where are vendor support personnel located geographically?"

Evidence to request: Third-party access policies, Privileged Access Management (PAM) systems, session recordings, vendor risk assessments

Red flags: Persistent vendor access, no session monitoring, vendors located in concerning jurisdictions, inability to quickly revoke access

Note: This is the highest point value question as third-party access is a primary sovereignty risk.

Domain 2: Technical Sovereignty

Domain Overview

Technical Sovereignty evaluates the degree of control an organization maintains over the foundational components of its technology stack—from hardware and firmware to application source code and runtime environments. High maturity signifies deliberate reduction in reliance on proprietary interfaces and single-vendor ecosystems, ensuring the ability to rebuild or migrate critical functions if necessary.

Key Focus Areas: Technology stack ownership, vendor lock-in mitigation, standardized frameworks, interoperability, hardware provenance, self-hosted runtimes, IP control, future-proofing

Common Discussion Topics: Open source adoption, Kubernetes and containerization, multi-cloud strategies, escrow agreements, supply chain security

Domain 2 Question Guide

Q1: Technology Stack Ownership & Control (1 point - Foundation)

What this measures: The extent to which the organization controls its foundational technology components

Key questions to ask:

"What percentage of your technology stack is open source vs. proprietary?"

"Can you independently operate and troubleshoot your core systems without vendor support?"

"Do you have internal expertise in the technologies running your critical infrastructure?"

"Could you rebuild your infrastructure from scratch if needed?"

Evidence to request: Technology inventory, internal skills matrix, documentation of core systems

Red flags: Heavy reliance on proprietary systems, lack of internal technical expertise, "vendor handles everything" mentality

Q2: Vendor Lock-in Risk Mitigation (2 points - Foundation)

What this measures: Assessment and mitigation of vendor lock-in risks

Key questions to ask:

"Have you assessed the effort required to switch to a different cloud provider?"

"Do your contracts include data portability and exit assistance clauses?"

"Are you using vendor-specific features that would be difficult to replace?"

"Have you calculated the total cost of vendor lock-in?"

Evidence to request: Lock-in risk assessment, vendor contracts with exit clauses, list of vendor-specific dependencies

Red flags: No exit strategy, heavy use of proprietary APIs, contracts without portability provisions

Q3: Standardised Technical Framework Adoption (3 points - Foundation)

What this measures: Use of industry-standard, non-proprietary technical frameworks

Key questions to ask:

"Do you have a list of approved technical standards for new projects?"

"Are you using industry-standard APIs and protocols?"

"How do you ensure new systems follow non-proprietary standards?"

"Can your systems interoperate with multiple vendors' products?"

Evidence to request: Technical standards documentation, API specifications, architecture review guidelines

Red flags: No standards policy, heavy reliance on vendor-specific APIs, systems that can't interoperate

Q4: Interoperability and Portability Strategy (4 points - Strategic)

What this measures: Ability to migrate workloads between platforms

Key questions to ask:

"Can you migrate a workload between cloud providers within a defined timeframe?"

"Are your applications containerized for portability?"

"Do you use Infrastructure-as-Code for reproducible deployments?"

"Have you tested migration procedures in a non-production environment?"

Evidence to request: Container adoption metrics, IaC repositories, migration test results

Red flags: No containerization strategy, manual infrastructure management, untested migration procedures

Q5: Hardware and Infrastructure Source Verification (5 points - Strategic)

What this measures: Control over hardware supply chain and verification

Key questions to ask:

"Do you know the origin and manufacturing location of your critical hardware?"

"Do you verify hardware integrity before deployment (TPM, secure boot)?"

"How do you validate firmware and hardware updates?"

"Do you have supply chain attestation for critical components?"

Evidence to request: Hardware procurement policies, supply chain verification procedures, TPM/secure boot configurations

Red flags: No hardware provenance tracking, unverified firmware updates, no supply chain validation

Q6: Self-Hosted Application Runtime Control (6 points - Strategic)

What this measures: Direct control over application runtime environments

Key questions to ask:

"Where are your critical applications hosted?"

"Do you have direct administrative control over the runtime environment?"

"Are you using self-hosted or sovereign-partner-hosted application servers?"

"Can the cloud provider access or modify your application runtime?"

Evidence to request: Hosting architecture diagrams, administrative access controls, runtime configuration

Red flags: Fully managed PaaS with no underlying access, provider-controlled runtimes, limited administrative rights

Q7: Code and Intellectual Property Control (7 points - Advanced)

What this measures: Ownership and control of source code and intellectual property

Key questions to ask:

"Do you own all custom application source code?"

"Where is your source code version control system hosted?"

"Do you have code escrow arrangements for vendor-developed software?"

"Are IP ownership rights clearly defined in all development contracts?"

Evidence to request: Source code repository locations, code escrow agreements, development contracts with IP clauses

Red flags: Vendor-owned custom code, third-party hosted version control, unclear IP ownership

Q8: Future-Proofing Technology Roadmaps (8 points - Advanced)

What this measures: Strategic planning to address sovereignty risks in technology evolution

Key questions to ask:

"Do you have a 3-5 year technology roadmap addressing sovereignty risks?"

"Have you identified high-risk technology dependencies?"

"Are you planning to replace proprietary components with sovereign alternatives?"

"How do you evaluate new technologies for sovereignty compliance?"

Evidence to request: Technology roadmap documents, dependency risk register, sovereignty evaluation criteria

Red flags: No long-term planning, reactive approach to sovereignty, no evaluation framework for new tech

Domain 3: Operational Sovereignty

Domain Overview

This domain examines the organization's autonomy and independence in executing critical business and IT operations. It ensures that essential functions can be performed without reliance on external human expertise or infrastructure outside the organization's direct control or trusted sovereign borders.

Key Focus Areas: Process documentation, managed service dependencies, IAM, internal skills, disaster recovery, supply chain vetting, incident response, operational autonomy

Common Discussion Topics: Break-glass procedures, in-house vs. outsourced operations, business continuity planning, geopolitical isolation scenarios

Domain 3 Question Guide

Q1: Operational Process Documentation (1 point - Foundation)

What this measures: Documentation of critical operational procedures for independence

Key questions to ask:

"Are all critical operational procedures documented?"

"Can your team execute operations without vendor documentation?"

"Where are operational runbooks stored?"

"How often are operational procedures reviewed and updated?"

Evidence to request: Operational runbooks, procedure documentation, documentation update logs

Red flags: Reliance on vendor documentation, undocumented critical procedures, tribal knowledge

Q2: Dependency on External Managed Services (2 points - Foundation)

What this measures: Internal operational capability vs. external dependencies

Key questions to ask:

"Do you have internal staff capable of performing all critical operations?"

"What percentage of operations require vendor involvement?"

"Have you identified skills gaps in your operations team?"

"Do you have training programs for sovereign operations?"

Evidence to request: Skills matrix, training programs, vendor dependency assessment

Red flags: Heavy vendor dependency, no internal capability, no skills development program

Q3: Access Control and Identity Management (3 points - Foundation)

What this measures: Operational resilience and recovery capabilities

Key questions to ask:

"Can you recover operations without vendor assistance?"

"Are disaster recovery plans tested regularly?"

"Do backup systems reside in sovereign infrastructure?"

"Can you maintain operations during a vendor outage?"

Evidence to request: DR test results, backup infrastructure documentation, continuity plans

Red flags: Untested DR plans, backup dependency on same vendor, no failover capability

Q4: Internal Skills and Competency Development (4 points - Strategic)

What this measures: Control over incident response processes

Key questions to ask:

"Do you control incident response processes end-to-end?"

"Can you investigate security incidents without vendor access to logs?"

"Where are security logs stored?"

"Do you have an internal Security Operations Center (SOC)?"

Evidence to request: Incident response playbooks, SOC operations, log management infrastructure

Red flags: Vendor-controlled incident response, logs only accessible via vendor, no internal SOC

Q5: Disaster Recovery and Business Continuity (5 points - Strategic)

What this measures: Control over deployment processes

Key questions to ask:

"Who manages your production deployment processes?"

"Can you deploy updates without vendor involvement?"

"Do you control CI/CD pipelines independently?"

"Where are deployment automation tools hosted?"

Evidence to request: CI/CD pipeline architecture, deployment automation tools, release management processes

Red flags: Vendor-managed deployments, external CI/CD platforms, no automated deployment capability

Q6: Supply Chain Transparency and Vetting (6 points - Strategic)

What this measures: Operational continuity through staff development

Key questions to ask:

"How quickly can you onboard new operational staff?"

"Do you have succession planning for critical operational roles?"

"Are operational skills concentrated with specific individuals?"

"Do you cross-train team members on critical functions?"

Evidence to request: Succession plans, cross-training programs, knowledge transfer documentation

Red flags: Single points of failure in staffing, no succession planning, concentrated expertise

Q7: Sovereign Incident Response Plan (7 points - Advanced)

What this measures: Independent infrastructure monitoring capability

Key questions to ask:

"Do you control infrastructure monitoring tools?"

"Where is operational telemetry data stored?"

"Can you detect anomalies without vendor-provided tools?"

"Do you have independent visibility into infrastructure health?"

Evidence to request: Monitoring tool architecture, telemetry data storage, alerting systems

Red flags: Vendor-provided monitoring only, no independent telemetry, limited visibility

Q8: Operational Autonomy in Critical Functions (8 points - Advanced)

What this measures: Ability to exit infrastructure and migrate workloads

Key questions to ask:

"Can you exit your current infrastructure within a defined timeframe?"

"Have you tested workload migration to alternative platforms?"

"Do you have automated tools for infrastructure migration?"

"What is your RTO (Recovery Time Objective) for a forced migration?"

Evidence to request: Migration test results, automated migration tools, documented RTO/RPO

Red flags: No exit strategy, untested migration, undefined RTO, manual migration processes

Domain 4: Assurance Sovereignty

Domain Overview

Assurance Sovereignty addresses the right, capability, and transparency required to verify the security and compliance claims of both internal systems and external vendors. It's the mechanism by which trust is verified, not assumed, through independent audits and continuous technical validation.

Key Focus Areas: Audit rights, sovereign SIEM, compliance verification, transparency requirements, sovereign certifications, continuous monitoring, security testing, vulnerability management

Common Discussion Topics: Right to audit clauses, SOC 2 Type II, penetration testing, third-party attestations, domestic vs. foreign auditors

Domain 4 Question Guide

Q1: Regular Security Audits Conducted (1 point - Foundation)

What this measures: Right and capability to audit service providers

Key questions to ask:

"Do you have the right to audit your service providers?"

"When was the last time you conducted a provider audit?"

"Can you perform unannounced audits?"

"Do you verify vendor compliance claims independently?"

Evidence to request: Audit rights in contracts, recent audit reports, audit schedules

Red flags: No audit rights, relying solely on vendor attestations, never conducted an audit

Q2: Control over Security Monitoring Data (2 points - Foundation)

What this measures: Compliance framework implementation and verification

Key questions to ask:

"Which compliance frameworks apply to your operations?"

"Do you have current compliance certifications (ISO 27001, SOC 2, etc.)?"

"How do you verify vendor compliance certifications?"

"Can you demonstrate continuous compliance?"

Evidence to request: Compliance certifications, compliance monitoring systems, verification procedures

Red flags: Unclear compliance requirements, expired certifications, no verification process

Q3: Risk Management Framework (3 points - Foundation)

What this measures: Control over security monitoring infrastructure

Key questions to ask:

"Do you control security monitoring tools?"

"Where are security logs aggregated and analyzed?"

"Can you detect threats without vendor-provided visibility?"

"Do you use sovereign-based security operations tools?"

Evidence to request: SIEM architecture, log aggregation infrastructure, monitoring tool ownership

Red flags: Vendor-controlled SIEM, logs not accessible independently, foreign-hosted security tools

Q4: Compliance with Local Security Standards (4 points - Strategic)

What this measures: Infrastructure integrity verification capabilities

Key questions to ask:

"How do you verify the integrity of your infrastructure?"

"Do you have tamper-detection mechanisms in place?"

"Can you detect unauthorized changes to your environment?"

"Do you use cryptographic verification for system integrity?"

Evidence to request: Integrity monitoring systems, tamper detection tools, baseline configurations

Red flags: No integrity verification, unable to detect tampering, no baseline management

Q5: Transparency in Vendor Security Practices (5 points - Strategic)

What this measures: Independent security testing and validation

Key questions to ask:

"Do you conduct regular penetration testing?"

"Are security assessments performed by independent third parties?"

"How do you validate security controls effectiveness?"

"Can you demonstrate security posture to regulators?"

Evidence to request: Penetration test reports, third-party assessment results, validation methodology

Red flags: No independent testing, relying on vendor testing only, unvalidated controls

Q6: Independent Certification and Vetting (6 points - Strategic)

What this measures: Compliance audit trail management

Key questions to ask:

"Where are compliance audit trails stored?"

"Are audit logs immutable and tamper-proof?"

"Can you produce compliance evidence on demand?"

"How long do you retain audit records?"

Evidence to request: Audit log infrastructure, immutability controls, retention policies

Red flags: Mutable audit logs, no retention policy, inability to produce evidence quickly

Q7: Ability to Invoke Sovereign Inspections (7 points - Advanced)

What this measures: Control plane security and monitoring

Key questions to ask:

"Do you control access to the cloud management plane?"

"Can you detect unauthorized control plane access?"

"Are control plane activities continuously monitored?"

"Do you have alerts for suspicious control plane operations?"

Evidence to request: Control plane access controls, monitoring configuration, alerting rules

Red flags: No control plane visibility, unmonitored access, no alerting for anomalies

Q8: Continuous Security Control Validation (8 points - Advanced)

What this measures: Tested capability to migrate due to assurance failures

Key questions to ask:

"Have you tested migration to alternative providers?"

"Do you have exit criteria that would trigger migration?"

"Can you migrate critical workloads within your defined timeframe?"

"Do you maintain automated migration playbooks?"

Evidence to request: Migration test results, exit criteria documentation, automated playbooks

Red flags: No tested migration capability, undefined exit criteria, manual migration only

Domain 5: Open Source

Sub-pillar of Technical Sovereignty

Domain Overview

This domain assesses the organization's strategic use of open-source software to reduce proprietary dependencies, increase transparency, and build internal capabilities. Mature organizations actively contribute to and influence open-source projects critical to their sovereignty goals. **Note:** Open Source capabilities are integrated as a sub-pillar within Technical Sovereignty domain in the assessment results.

Key Focus Areas: Open source strategy, community participation, license compliance, vulnerability management, sovereign distributions, contribution policies, internal expertise, project governance

Common Discussion Topics: Red Hat Enterprise Linux, Kubernetes, Apache projects, InnerSource, security scanning, open source vs. commercial support

Domain 5 Question Guide

Q1: OSS Policy and Usage Guidelines (1 point - Foundation)

What this measures: Strategic approach to open source software adoption

Key questions to ask:

"What percentage of your stack uses open source software?"

"Do you have a policy favoring open source adoption?"

"Can you justify proprietary software choices?"

"Have you evaluated open source alternatives for proprietary tools?"

Evidence to request: OSS adoption policy, software inventory showing OSS vs proprietary, justification process

Red flags: No OSS policy, default to proprietary solutions, no evaluation of alternatives

Q2: Internal OSS Skills and Expertise (2 points - Foundation)

What this measures: Governance and tracking of open source components

Key questions to ask:

"Do you have an OSS governance framework?"

"How do you track open source components and their licenses?"

"Do you have processes for OSS security vulnerability management?"

"Can you identify all OSS dependencies in your applications?"

Evidence to request: OSS governance documentation, dependency tracking tools (SBOM), vulnerability scanning

Red flags: No OSS governance, unknown dependencies, no vulnerability tracking

Q3: Source Code Escrow Arrangements (3 points - Foundation)

What this measures: Active participation in open source communities

Key questions to ask:

"Do you contribute code, documentation, or resources to OSS projects?"

"Are developers encouraged to participate in OSS communities?"

"Do you sponsor or support critical OSS projects you depend on?"

"Have you open-sourced any internal tools or projects?"

Evidence to request: OSS contribution records, community participation metrics, sponsorship agreements

Red flags: No contributions, developers not allowed to participate, only consuming OSS

Q4: Dependency Risk Assessment (4 points - Strategic)

What this measures: Internal capability to support critical OSS

Key questions to ask:

"Do you have internal expertise to support critical OSS components?"

"Can you fork and maintain OSS projects if needed?"

"Do you have developers skilled in the OSS technologies you use?"

"Can you provide emergency support for OSS issues?"

Evidence to request: Skills matrix for OSS technologies, fork capability demonstration, support procedures

Red flags: No internal OSS expertise, unable to support critical components, total reliance on community

Q5: Forking Strategy for Critical OSS (5 points - Strategic)

What this measures: OSS security and vulnerability management

Key questions to ask:

"How do you monitor OSS security advisories?"

"Do you have a process for patching OSS vulnerabilities?"

"Can you assess OSS security independently?"

"Do you perform security scanning of OSS components?"

Evidence to request: Vulnerability monitoring systems, patching processes, security scanning tools

Red flags: No security monitoring for OSS, reactive patching only, no scanning capability

Q6: Contribution to Strategic OSS Projects (6 points - Strategic)

What this measures: Assessment of OSS project health and sustainability

Key questions to ask:

"Have you evaluated the maturity and sustainability of OSS projects you depend on?"

"Do you assess OSS project governance and community health?"

"What happens if a critical OSS project becomes unmaintained?"

"Do you have contingency plans for OSS project failures?"

Evidence to request: Project health assessments, sustainability criteria, contingency plans

Red flags: No project assessment, dependency on unmaintained projects, no contingency planning

Q7: Active OSS Community Engagement (7 points - Advanced)

What this measures: OSS supply chain security

Key questions to ask:

"Do you verify the integrity and provenance of OSS components?"

"Do you use signed releases and verify signatures?"

"Can you trace OSS components back to official sources?"

"Do you protect against OSS supply chain attacks?"

Evidence to request: Signature verification processes, provenance tracking, supply chain security controls

Red flags: No signature verification, unverified sources, no supply chain security

Q8: Ability to Influence OSS Roadmaps (8 points - Advanced)

What this measures: Strategic use of OSS for sovereignty goals

Key questions to ask:

"Do you leverage OSS for strategic sovereignty goals?"

"Have you replaced proprietary tools with OSS alternatives?"

"Is OSS adoption part of your sovereignty roadmap?"

"How do you measure the sovereignty benefits of OSS?"

Evidence to request: Sovereignty roadmap showing OSS initiatives, replacement projects, metrics

Red flags: No strategic OSS approach, no measurable sovereignty benefits, OSS not in roadmap

Domain 6: Executive Oversight

Executive Oversight ensures that sovereignty concerns are understood, prioritized, and actively managed at the highest levels of the organization. This domain measures board and C-suite engagement, dedicated budgets, governance structures, and accountability for sovereignty outcomes.

Key Focus Areas: Board awareness, dedicated governance, budget allocation, sovereignty policies, risk management, accountability, strategic planning, regulatory engagement

Common Discussion Topics: Board reporting, sovereignty champions, dedicated budgets vs. embedded costs, KPIs and metrics, regulatory relationships

Domain 6 Question Guide

Q1: Designated Executive Sponsor (1 point - Foundation)

What this measures: Executive and board-level awareness of sovereignty

Key questions to ask:

"Is digital sovereignty on the board's risk agenda?"

"Do executives understand sovereignty risks and opportunities?"

"Is there a designated executive owner for sovereignty?"

"How often is sovereignty discussed at the executive level?"

Evidence to request: Board meeting agendas, executive sponsor designation, governance documentation

Red flags: No board discussion, no executive ownership, sovereignty relegated to IT only

Q2: Defined Digital Sovereignty Policy (2 points - Foundation)

What this measures: Formal sovereignty strategy and alignment

Key questions to ask:

"Do you have a formal digital sovereignty strategy?"

"Is the strategy aligned with business objectives?"

"Does the strategy include measurable goals and timelines?"

"Is the strategy reviewed and updated regularly?"

Evidence to request: Sovereignty strategy document, goals and metrics, review schedules

Red flags: No formal strategy, unclear goals, no alignment with business objectives

Q3: Budget Allocation for Sovereignty Initiatives (3 points - Foundation)

What this measures: Financial commitment to sovereignty

Key questions to ask:

"Is there dedicated budget for sovereignty initiatives?"

"How much are you investing in sovereignty improvements?"

"Are sovereignty costs tracked separately?"

"Do you measure ROI on sovereignty investments?"

Evidence to request: Budget allocation, investment tracking, ROI measurements

Red flags: No dedicated budget, costs buried in general IT spend, no ROI tracking

Q4: Integration into Organisational Strategy (4 points - Strategic)

What this measures: Sovereignty maturity tracking and KPIs

Key questions to ask:

"How do you track sovereignty maturity over time?"

"Do you have KPIs for sovereignty progress?"

"Are sovereignty metrics reported to executives?"

"How do you benchmark against industry peers?"

Evidence to request: KPI dashboards, tracking systems, benchmark reports

Red flags: No tracking, no defined KPIs, no benchmarking

Q5: Regular Reporting to the Board (5 points - Strategic)

What this measures: Sovereignty integration into procurement

Key questions to ask:

"Is sovereignty integrated into procurement processes?"

"Do vendor selection criteria include sovereignty requirements?"

"Are contracts reviewed for sovereignty compliance?"

"Do you negotiate sovereignty terms with vendors?"

Evidence to request: Procurement policies, vendor selection criteria, contract templates

Red flags: No sovereignty in procurement, standard vendor contracts accepted, no negotiation

Q6: Sovereignty Culture and Awareness Program (6 points - Strategic)

What this measures: Employee awareness and training

Key questions to ask:

"Do employees understand sovereignty requirements?"

"Is sovereignty training provided to relevant staff?"

"Is sovereignty awareness part of onboarding?"

"How do you promote a culture of sovereignty?"

Evidence to request: Training programs, onboarding materials, awareness campaigns

Red flags: No training, employees unaware, sovereignty not in culture

Q7: Dedicated Sovereignty Governance Board (7 points - Advanced)

What this measures: Regulatory engagement and awareness

Key questions to ask:

"Do you engage with regulators on sovereignty topics?"

"Are you monitoring regulatory developments?"

"Do you participate in industry sovereignty initiatives?"

"How do you stay ahead of sovereignty regulations?"

Evidence to request: Regulatory engagement records, monitoring systems, industry participation

Red flags: No regulatory engagement, reactive to regulations, no industry participation

Q8: Key Performance Indicators (KPIs) Defined (8 points - Advanced)

What this measures: External communication of sovereignty posture

Key questions to ask:

"Do you communicate sovereignty posture to stakeholders?"

"Is sovereignty part of customer value propositions?"

"How do you demonstrate sovereignty to clients?"

"Do you publish sovereignty commitments publicly?"

Evidence to request: Public commitments, customer materials, stakeholder communications

Red flags: No external communication, sovereignty not mentioned to customers, no public commitments

Domain 7: Managed Services Sub-pillar of Operational Sovereignty

Domain Overview

This domain evaluates how the organization manages relationships with external managed service providers while maintaining sovereignty. It addresses vendor selection criteria, contractual controls, geographic restrictions, transition planning, and the balance between operational efficiency and sovereign control. **Note:** Managed Services capabilities are integrated as a sub-pillar within Operational Sovereignty domain in the assessment results.

Key Focus Areas: Vendor selection criteria, contractual controls, geographic restrictions, data access limitations, performance monitoring, transition planning, alternatives evaluation, insourcing capabilities

Common Discussion Topics: Domestic vs. foreign MSPs, data center locations, support personnel jurisdictions, exit strategies, dual-source strategies

Domain 7 Question Guide

Q1: Region and Zoning Control (1 point - Foundation)

What this measures: Inventory and classification of managed service providers

Key questions to ask:

"Do you have an inventory of all managed service providers?"

"What critical functions are outsourced?"

"Do you understand the sovereignty implications of each service?"

"Have you classified managed services by sovereignty risk?"

Evidence to request: MSP inventory, outsourced functions list, risk classifications

Red flags: No MSP inventory, unknown sovereignty risks, unclassified services

Q2: Sovereign Image and Container Registry (2 points - Foundation)

What this measures: Contractual data ownership and portability

Key questions to ask:

"Do contracts define data ownership unambiguously?"

"Can you access and export your data at any time?"

"Do you retain control over encryption keys?"

"Are data portability rights contractually guaranteed?"

Evidence to request: MSP contracts showing data ownership clauses, portability provisions

Red flags: Ambiguous ownership, limited data access, vendor-controlled keys, no portability guarantee

Q3: Resource Dependency Mapping (3 points - Foundation)

What this measures: Geographic and jurisdictional control of MSPs

Key questions to ask:

"Where are managed service providers located?"

"What is the legal jurisdiction governing service contracts?"

"Are service personnel located in trusted jurisdictions?"

"Can providers access your data from foreign locations?"

Evidence to request: Provider locations, contract governing law, personnel jurisdiction documentation

Red flags: Foreign-based providers, foreign jurisdiction contracts, unrestricted access locations

Q4: Hyperscaler Data Access Vetting (4 points - Strategic)

What this measures: Exit planning and transition capabilities

Key questions to ask:

"Do contracts include service exit and transition assistance?"

"How long would it take to migrate from a managed service?"

"Have you tested exit procedures?"

"Do you have alternatives identified for critical managed services?"

Evidence to request: Exit clauses in contracts, transition plans, alternative provider evaluations

Red flags: No exit provisions, undefined transition time, untested procedures, no alternatives

Q5: Network Egress/Ingress Path Control (5 points - Strategic)

What this measures: Visibility into managed service operations

Key questions to ask:

"Do you have visibility into managed service operations?"

"Can you audit provider activities independently?"

"Do you receive detailed operational logs?"

"Can you detect provider security incidents?"

Evidence to request: Audit capabilities, operational logs access, monitoring dashboards

Red flags: No visibility, unable to audit, limited logging, no incident detection

Q6: Configuration-as-Code Ownership (6 points - Strategic)

What this measures: Service level agreements and accountability

Key questions to ask:

"Do contracts define SLAs and penalties clearly?"

"Are sovereignty requirements included in SLAs?"

"How do you monitor SLA compliance?"

"What recourse do you have for SLA violations?"

Evidence to request: SLA documentation, sovereignty requirements in contracts, compliance monitoring

Red flags: Weak SLAs, no sovereignty requirements, no monitoring, limited recourse

Q7: Control Plane Audit and Integrity (7 points - Advanced)

What this measures: Provider security and compliance verification

Key questions to ask:

"Have you verified provider security certifications?"

"Do you conduct regular provider risk assessments?"

"Are providers subject to the same security requirements as internal teams?"

"How do you ensure provider compliance with your standards?"

Evidence to request: Provider certifications, risk assessment reports, security requirements

Red flags: Unverified certifications, no risk assessments, different standards for providers

Q8: Multi-Cloud Exit Strategy Testing (8 points - Advanced)

What this measures: Multi-provider strategy for resilience

Key questions to ask:

"Do you use multiple providers to avoid dependency on a single vendor?"

"Can critical services failover to alternative providers?"

"Have you tested multi-provider resilience?"

"Do you have geographic diversity in service providers?"

Evidence to request: Multi-provider architecture, failover tests, geographic distribution

Red flags: Single provider dependency, no failover capability, untested resilience, no geographic diversity

Post-Assessment Activities

Results Interpretation

After completing the assessment, guide the customer through understanding their results.

Understanding the Spider Chart

The spider/radar chart provides a visual representation of maturity across all domains:

Balanced shape: Consistent maturity across domains

Spikes and valleys: Strength in some areas, gaps in others

Small overall size: Early-stage maturity (common and expected)

Industry comparison: Compare against weighted targets for their LOB

Typical Results

Most organizations on their first assessment score:

Overall average: 30–45% (Managed to Defined levels)

Strong domains: Often Executive Oversight, basic Data Protection

Weak domains: Often Cryptographic Key Management, Workload Protection, Operational Autonomy

Reassure customers that these results are normal starting points, not failures.

New: Thematic Capability View

The results page now includes a revolutionary **Themes** tab that reorganizes all 56 capabilities by concept rather than domain:

8 Thematic Groups: Governance & Policy, Data & Privacy, Risk & Compliance, Technical Control, Operational Resilience, Vendor & Dependencies, Monitoring &

Security, Open Source

Visual Summary Dashboard: Interactive cards showing maturity percentage for each theme at-a-glance

Cross-Domain Pattern Recognition: Identify if weaknesses are organizational (e.g., weak governance everywhere) vs domain-specific

Interactive Overview Display: Hover over theme cards to see detailed thematic context

Using Thematic View in Workshops

The thematic view reveals patterns that domain-based views miss:

"You score 67% on Governance & Policy across all domains" - Shows executive buy-in exists

"Technical Control is only 50%" - Reveals implementation gaps despite good policy

"Vendor & Dependencies is 52%" - Highlights systemic vendor management issues

Use this view to have strategic conversations: "Your governance is strong, but technical implementation lags—let's discuss resourcing."

Progress Tracking During Assessment

The assessment interface now displays a real-time progress counter in the header:

Live counter: "X of 56 capabilities rated" updates as you move sliders

Completion visibility: Helps facilitators ensure all capabilities are reviewed

Workshop pacing: Monitor progress to stay on schedule during facilitated sessions

Score Discussion Points

Celebrate strengths: "You're scoring well in [domain]—let's talk about how you achieved that"

Identify quick wins: "Foundation questions at Level 1 are often easy to advance with policy documentation"

Highlight strategic gaps: "The low score in Cryptographic Key Management is concerning given your industry requirements"

Consider domain weighting: "Your LOB weights Data Sovereignty at 2×, so gaps here have extra impact"

Gap Analysis and Prioritization

Work with the customer to translate scores into actionable priorities:

Prioritization Framework

Priority	Criteria	Example
Critical (0-3 months)	Regulatory requirement, high industry weighting, Level 1 on high-point questions	Implementing HSM-based key management for healthcare patient data
High (3-6 months)	Significant sovereignty risk, medium weighting, Level 2 on strategic questions	Establishing sovereign audit rights with cloud providers
Medium (6-12 months)	Important capability, standard weighting, Level 2-3 on foundation questions	Implementing data classification and discovery tools
Low (12+ months)	Optimization, already at Level 3+, advanced questions	Establishing open source contribution programs

Recommended Roadmap Structure

- Phase 1: Foundation (0-6 months)
Policy development, basic controls, compliance alignment, data inventory, vendor assessment
- Phase 2: Strategic (6-18 months)

Technical implementations, key management, vendor migrations, skills development, tooling deployment

Phase 3: Advanced (18-36 months)

Continuous monitoring, optimization, innovation, industry leadership, operational autonomy

Exporting and Sharing Results

Help customers export and distribute results appropriately:

Export Results: Use the Export functionality to save as JSON for future import/comparison

Screenshot the Spider Chart: Visual summaries are powerful for executive presentations

Document Key Findings: Capture top 3-5 gaps and recommendations in a summary document

Share Appropriately: Consider audience when sharing (Board vs. technical team vs. vendors)

Next Steps and Follow-up

Schedule follow-up activities to maintain momentum:

Recommended Follow-up Schedule

Week 1: Send detailed results summary and initial recommendations

Week 2-3: Schedule roadmap planning workshop (2 hours)

Month 2: Check-in on quick wins and foundation initiatives

Quarter 2: Progress review and assessment update for changed answers

Annual: Full reassessment to measure improvement

Engagement Opportunities

The assessment often reveals opportunities for further engagement:

Architecture Reviews: Deep-dive assessments of specific systems or domains

Policy Development: Creating missing governance and compliance documentation

Technology Selection: Evaluating sovereign-compliant alternatives to current tools

Skills Training: Targeted training on identified capability gaps

Implementation Services: Deploying specific solutions (HSMs, DLP, PAM, etc.)

Managed Services: Sovereign-compliant managed services to fill operational gaps

Facilitator Tips & Best Practices

Do's

Do prepare thoroughly: Review the customer's industry, known technologies, and recent news

Do set expectations: Explain that honest assessment is better than inflated scores

Do ask for evidence: "Can you show me?" is your most important question

Do take detailed notes: Capture context, concerns, and follow-up items

Do remain neutral: You're a facilitator, not a judge; help them self-assess accurately

Do celebrate progress: Acknowledge what they're doing well

Do connect dots: "Your answer here relates to what you said about [other domain]"

Do respect time: Keep things moving; park lengthy discussions for later

Do follow up: Send materials promptly and schedule next steps before leaving

Don'ts

Don't sell during assessment: Stay consultative; sales conversations come after results review

Don't accept vague answers: "We're planning to" or "We're working on it" usually means Level 1

Don't inflate scores: It only hurts their planning and your credibility

Don't argue: If they insist on a rating despite lack of evidence, document the discrepancy

Don't rush foundation questions: They're as important as advanced questions for overall maturity

Don't skip breaks: Assessment fatigue leads to poor decisions

Don't assume technical knowledge: Explain concepts clearly for non-technical executives

Don't dismiss concerns: If they're worried about something, explore it

Remote Facilitation Tips

When conducting assessments remotely:

Use video to read body language and maintain engagement

Share your screen showing the assessment tool for transparency

Use collaboration tools (digital whiteboard) for visual discussions

Record the session (with permission) for reference

Check in verbally more frequently: "Is everyone still with me?"

Use chat for parking lot items and questions

Send materials in advance as remote participants may not have printed copies

Dealing with Challenging Personalities

The Over-Confident Executive

Behavior: Claims high maturity without evidence, dismisses concerns, believes "we have the best security"

Approach: Acknowledge their confidence, then request specific evidence. Use data and industry benchmarks. Ask their technical team to verify claims. Frame lower scores as "industry-standard journey" rather than failures.

The "Too Busy" Participant

Behavior: Late to session, distracted, checking phone, wants to rush through

Approach: Respectfully emphasize the value of their time investment. Show early results to demonstrate value. Offer to reschedule if they can't focus. Break into shorter sessions if needed.

The Defensive CISO

Behavior: Takes low scores personally, explains why gaps aren't their fault, blames budget/management

Approach: Emphasize this is organizational assessment, not personal evaluation. Validate resource constraints. Position results as ammunition for budget requests. Frame gaps as opportunities to demonstrate need for investment.

The Technical Perfectionist

Behavior: Debates every nuance, wants to discuss technical details extensively, struggles to choose between maturity levels

Approach: Appreciate their thoroughness. Set time limits for each question. Offer to deep-dive on specific topics afterward. Remind that perfect accuracy is less important than directional understanding. Use "parking lot" for detailed technical discussions.

Appendix

Downloadable Templates

Ready-to-use templates are available to support your assessment delivery:

Access All Templates

Visit the **Templates Library** (<templates/index.html>) for:

Full-Day Workshop Agenda: Comprehensive one-day format with detailed schedule

Short Assessment Agenda: 2-hour focused assessment format

Email Templates: Pre-written emails for invitation, preparation, follow-up, and check-ins

Executive Summary Template: One-page results summary for C-suite presentation

Glossary of Key Terms

Term	Definition
BYOK	Bring Your Own Key - Customer-generated encryption keys imported to cloud provider
CLOUD Act	US law allowing government access to data held by US companies regardless of location
Confidential Computing	Protection of data during processing using hardware-based secure enclaves

Term	Definition
Data Residency	Physical location where data is stored
Data Sovereignty	Legal and technical control over data, including ability to resist foreign access demands
DLP	Data Loss Prevention - Tools to monitor and prevent unauthorized data transfers
EKM	External Key Management - Encryption keys managed outside cloud provider infrastructure
HSM	Hardware Security Module - Dedicated cryptographic processor for key management
PAM	Privileged Access Management - System for controlling and monitoring administrative access
SCA	Software Composition Analysis - Scanning third-party code for vulnerabilities
TEE	Trusted Execution Environment - Secure area of processor for sensitive operations
Zero Trust	Security model assuming no implicit trust, requiring verification for all access

Reference Materials

CMMI Framework: <https://cmmiinstitute.com/>

GDPR: General Data Protection Regulation (EU)

NIS2 Directive: Network and Information Security Directive (EU)

DORA: Digital Operational Resilience Act (EU)

FedRAMP: Federal Risk and Authorization Management Program (US)

Cloud Security Alliance: <https://cloudsecurityalliance.org/>

Sample Email Templates

Pre-Assessment Email

Subject: Preparation for Digital Sovereignty Maturity Assessment - [Date]

Dear [Stakeholders],

Thank you for scheduling a Full Maturity Assessment. This session will evaluate your organization's Digital Sovereignty capabilities across 7 key domains using a proven 5-level maturity framework.

Session Details:

Date/Time: [Date/Time]

Location/Link: [Details]

Required Participants: CIO/CTO, CISO, Cloud/Infrastructure Lead, Compliance Officer

Please prepare:

List of cloud providers and services used

Current compliance frameworks and certifications

Data classification and residency policies

Key vendor relationships and contracts

Looking forward to our session.

Best regards,

[Your Name]

Post-Assessment Email

Subject: Digital Sovereignty Assessment Results and Next Steps

Dear [Stakeholders],

Thank you for participating in yesterday's maturity assessment. Your engagement and candor were excellent.

Key Findings:

Overall maturity: [X]% ([Maturity Level])

Strongest domain: [Domain] at [Y]%

Priority gap: [Domain] at [Z]%

Attached you'll find:

Detailed results export

Spider chart visualization

Initial recommendations summary

Recommended Next Steps:

Review results with your teams (Week 1)

Roadmap planning workshop (Week 2-3)

Prioritize quick wins for immediate action

I'll follow up next week to schedule our roadmap session.

Best regards,

[Your Name]

Quick Reference: Maturity Level Indicators

Level	Key Indicators	Common Language
1	No policy, ad-hoc, reactive, "we're planning to"	"We know we need to do this"
2	Draft policies, pilots, project plans, some implementation	"We're working on it"
3	Approved policies, widespread deployment, documented standards	"We have this in place"
4	Metrics, dashboards, KPIs, regular reporting, measured outcomes	"We measure and optimize this"
5	Continuous improvement, innovation, industry leadership	"We're leading the industry"